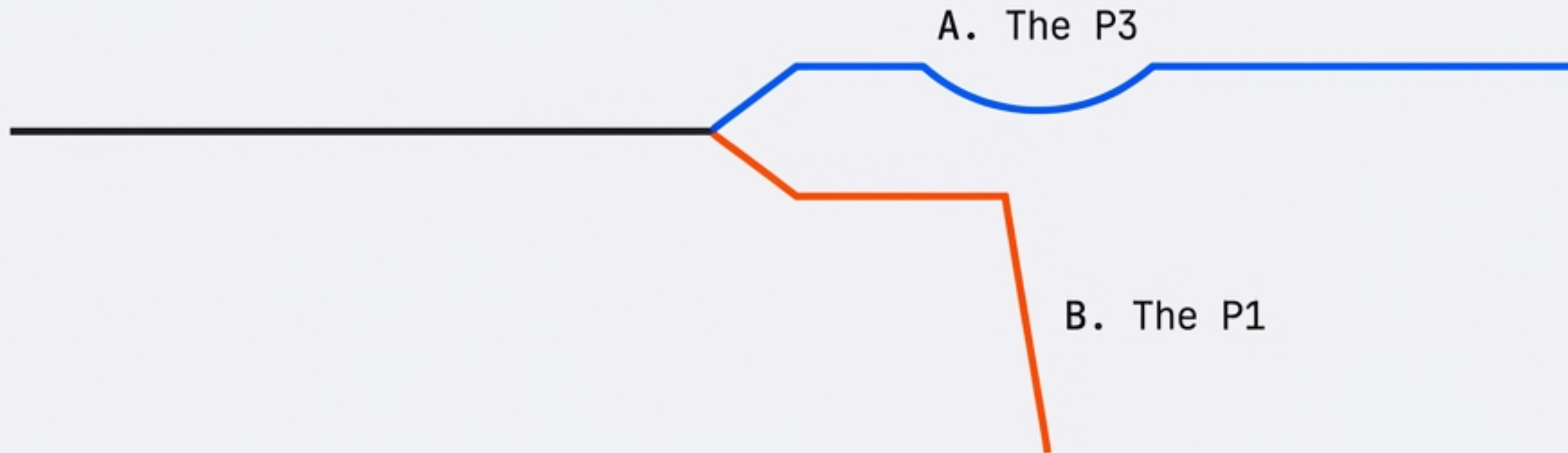


The P3-as-P1 Philosophy

Why Near Misses Matter More Than Incidents



THE STANDARD QUESTION

What happened?

THE REQUIRED QUESTIONS

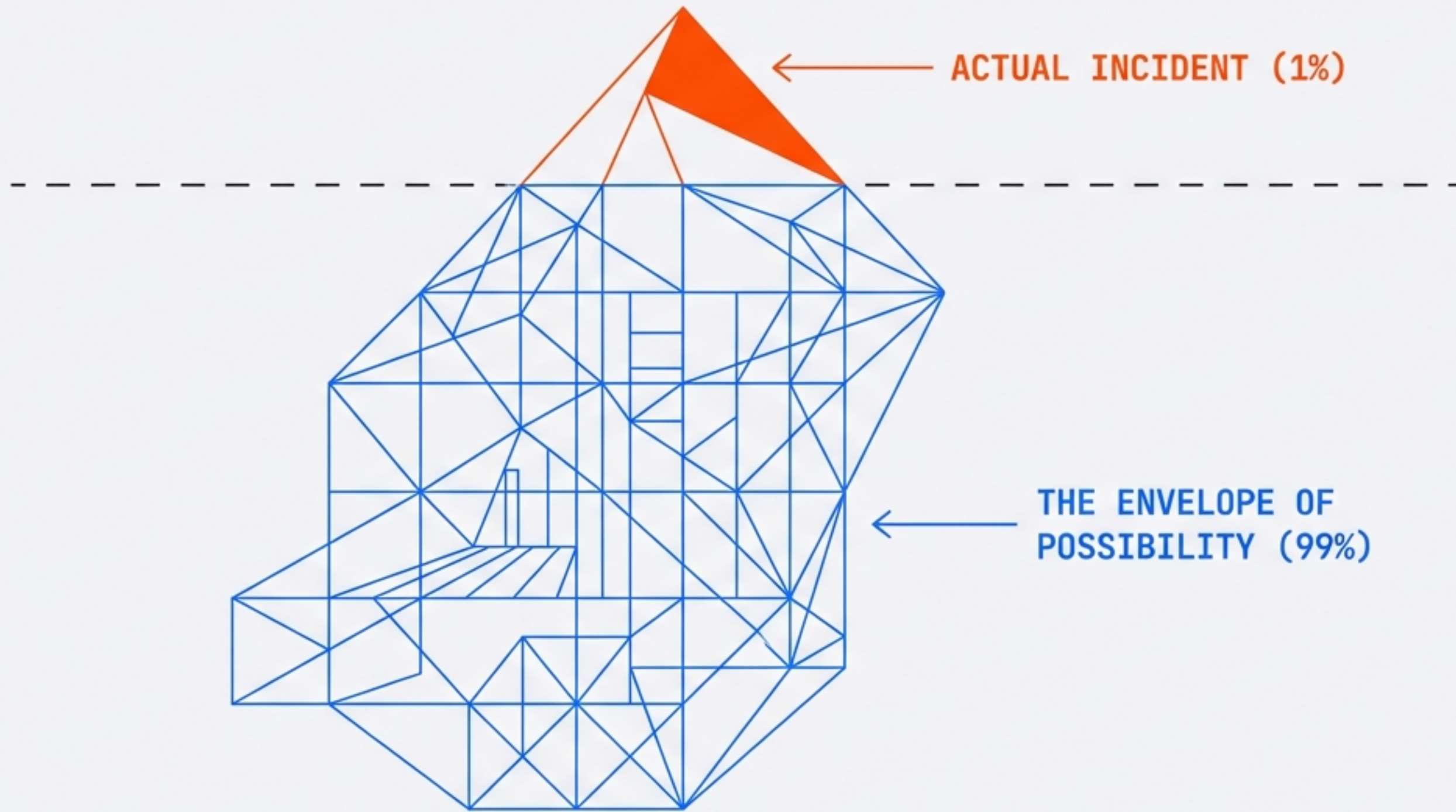
1. What could have happened?
2. How did we get here?
3. Was this the maximum possible damage?

THE GOAL

Move from Outcome Bias to Systemic Rigor.

You Cannot Build Safety on Luck

The asymmetry of risk.



THE ILLUSION:

Celebrating that an attacker turned right instead of left.

THE REALITY:

Actual damage is often 0.1% to 10% of what was mechanically possible.

THE SHIFT:

Stop assessing risk by the outcome (£200).
Start assessing by the union of all possible damage (Full Compromise).

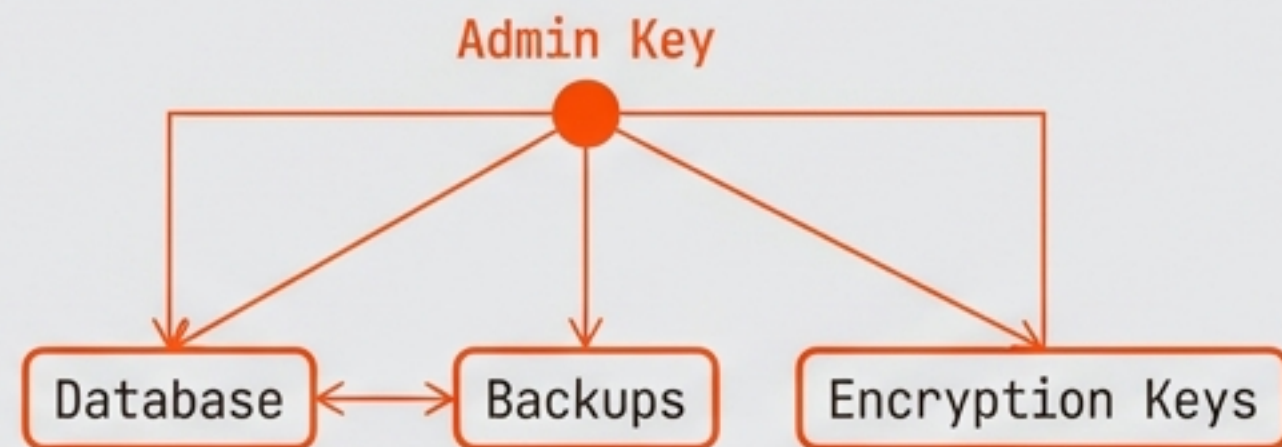
The Illusion of 'Incident Closed'

WHAT THE BUSINESS SEES



- **Event:** Crypto mining on unauthorized instances.
- **Impact:** £200 compute cost.
- **Action:** Key rotated.
- **Status:** FIXED ✓

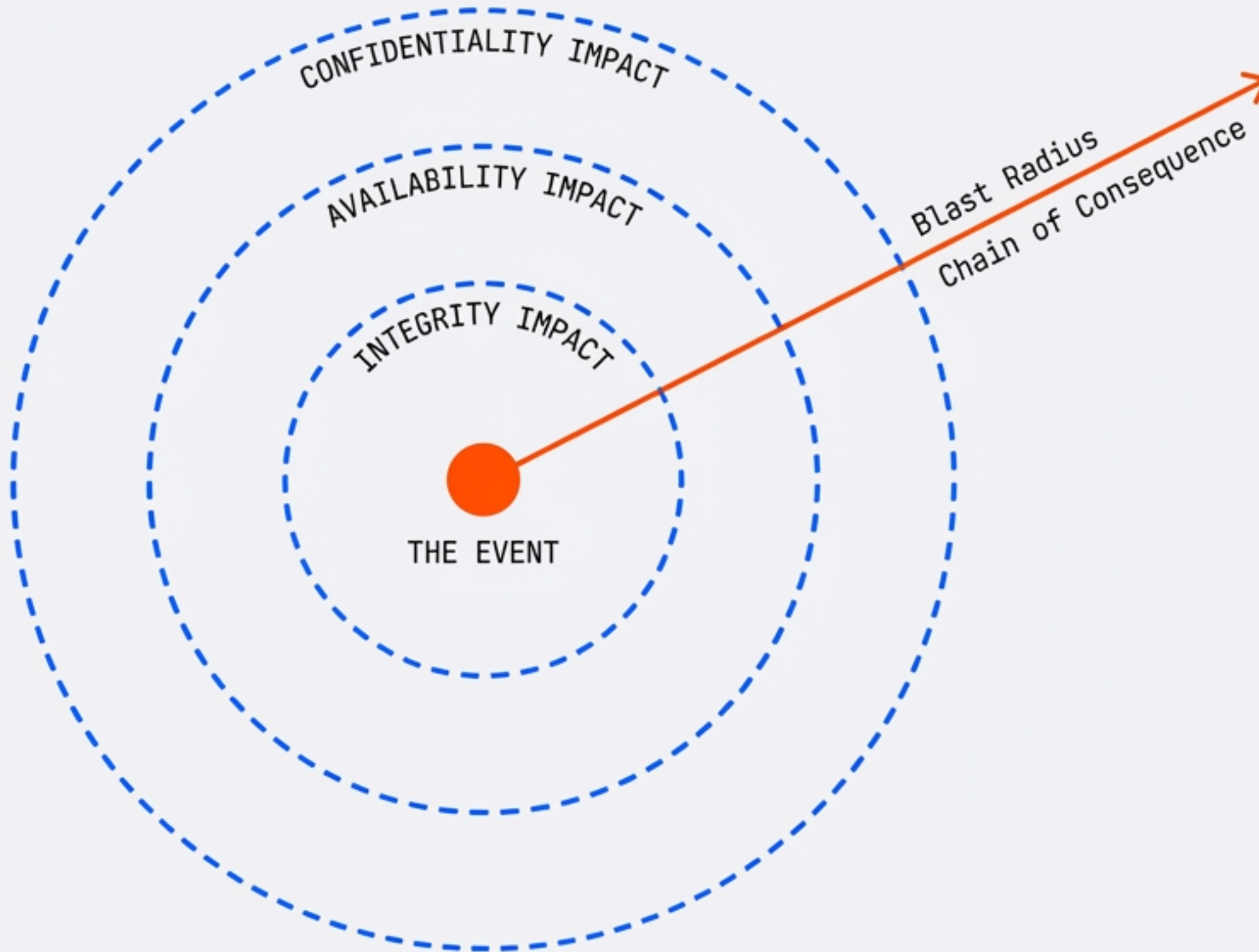
WHAT ACTUALLY HAPPENED



- **Event:** Attacker had full administrative access to entire AWS estate.
- **Potential:** Database exfiltration, Backup destruction, Ransomware.
- **Reality:** The attacker lacked imagination, not access.
- **Status:** CRITICAL SYSTEMIC FAILURE ⚠️

"The fact that this attacker only wanted cheap compute is not a security control. It's luck."

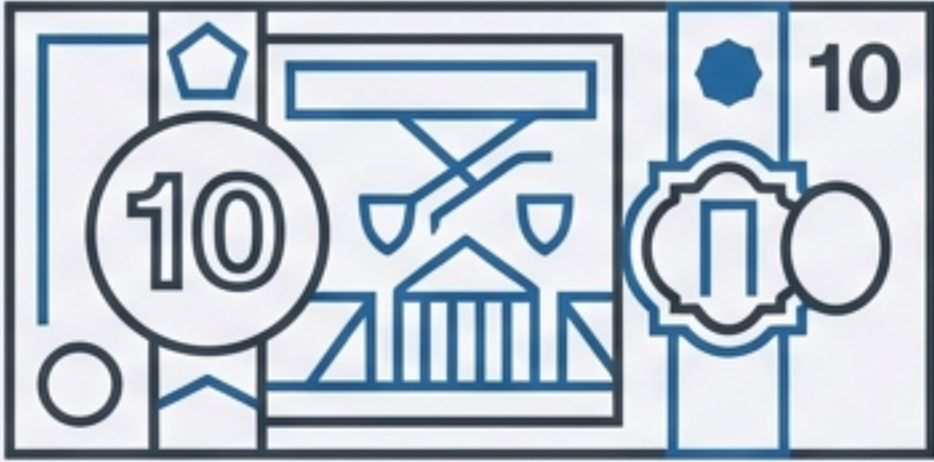
The Union of All Possible Damage



THE METRIC:

- The risk you are accepting is not the incident that occurred.
- It is the full scope of what that specific vector allowed.
- Data Integrity → Availability → Confidentiality

The £10 Metaphor



THE LOSS



THE TARGET



THE POTENTIAL

THE SCENARIO: Someone steals £10 from your hand.

OUTCOME ANALYSIS (FLAWED)

- I lost £10.
- I can afford this.
- Risk Accepted.

RISK ANALYSIS (CORRECT)

- **Proximity**: How did they get close enough to touch me?
- **Potential**: Could they have taken the wallet? The keys?
- **Recurrence**: Will they return tomorrow?

If you only assess the £10, you are assessing history, not risk.

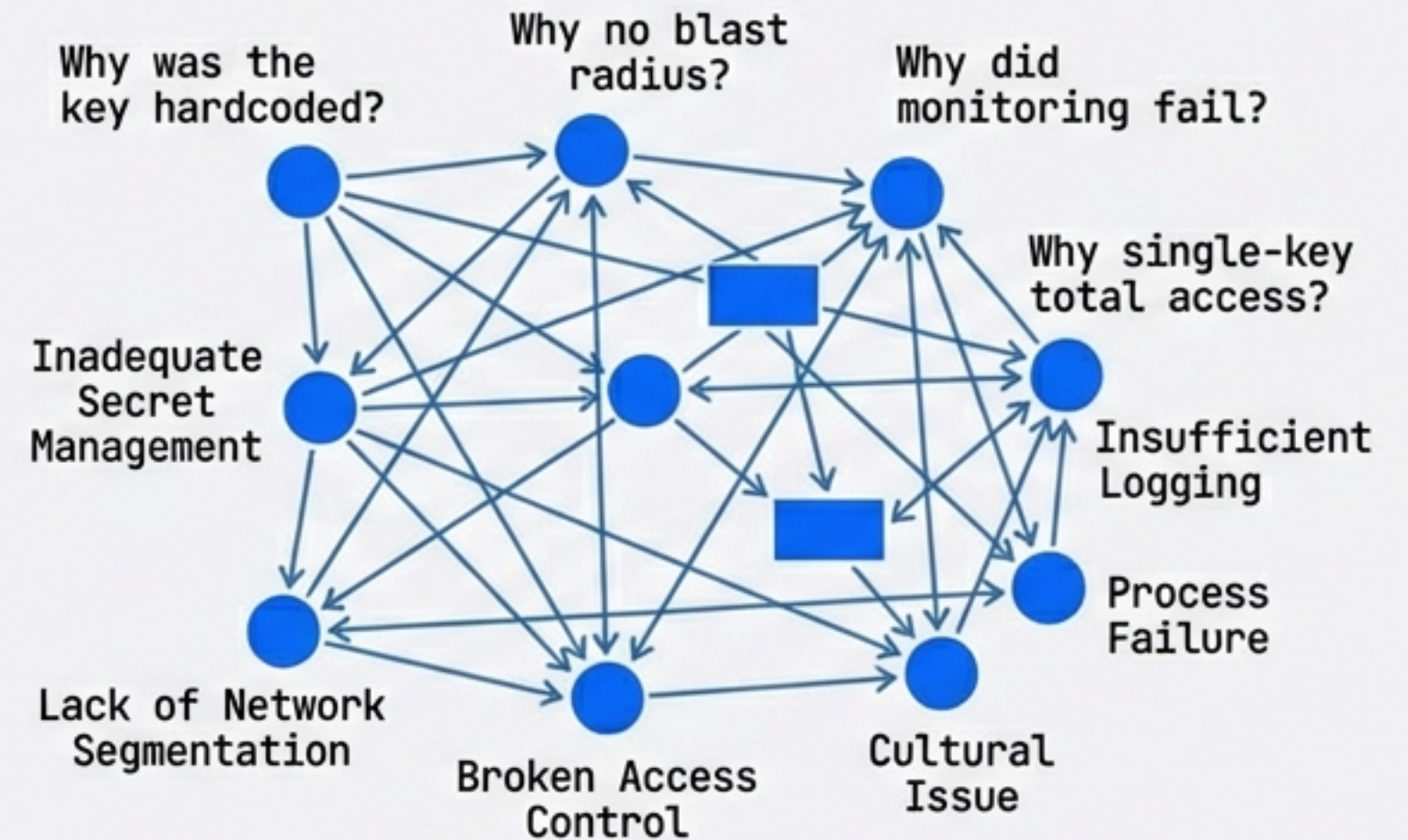
First Stories vs. Second Stories

THE FIRST STORY (Surface)



This tells you what happened.

THE SECOND STORY (Systemic)

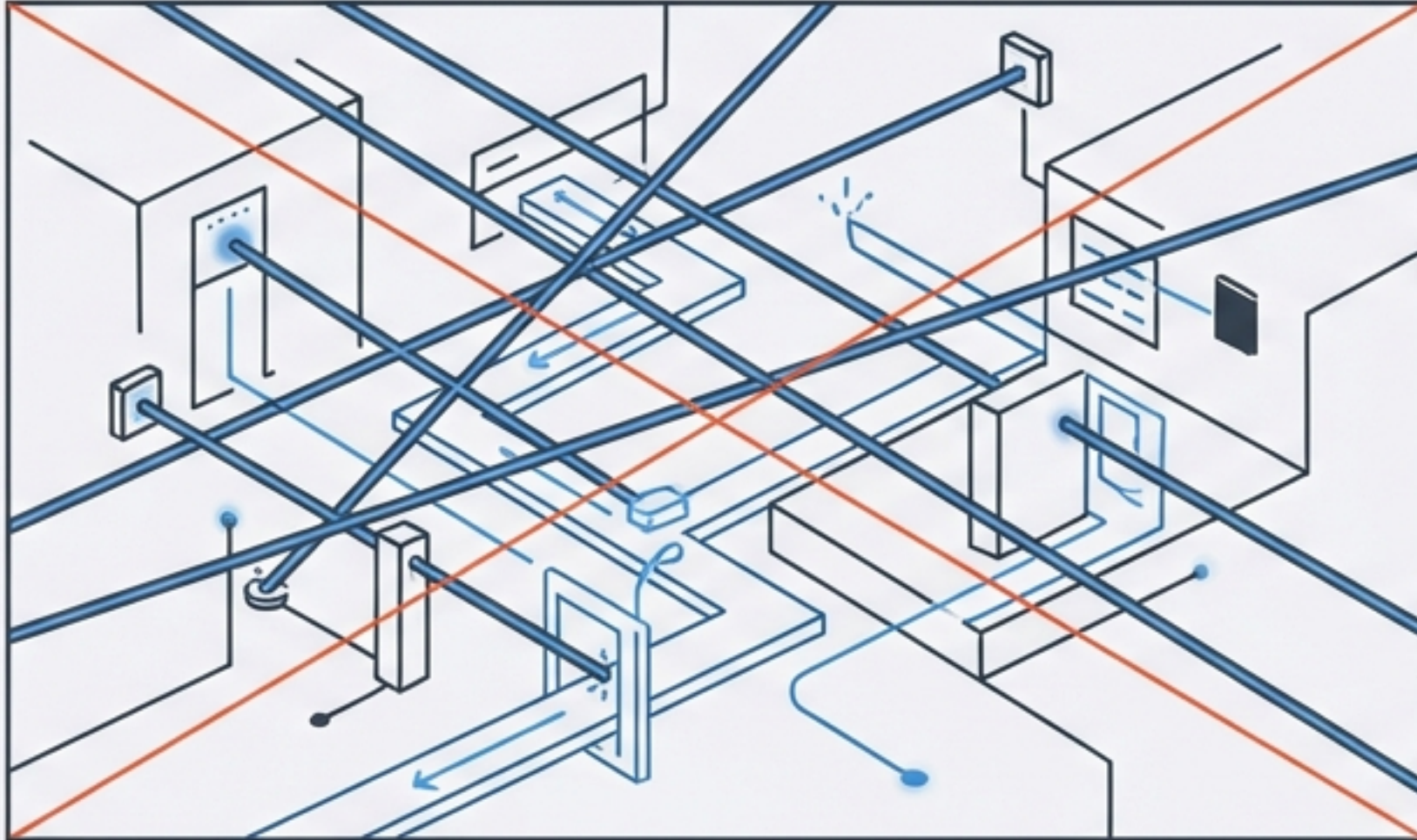


This tells you why it happened.

Incidents do not create problems; they reveal them.

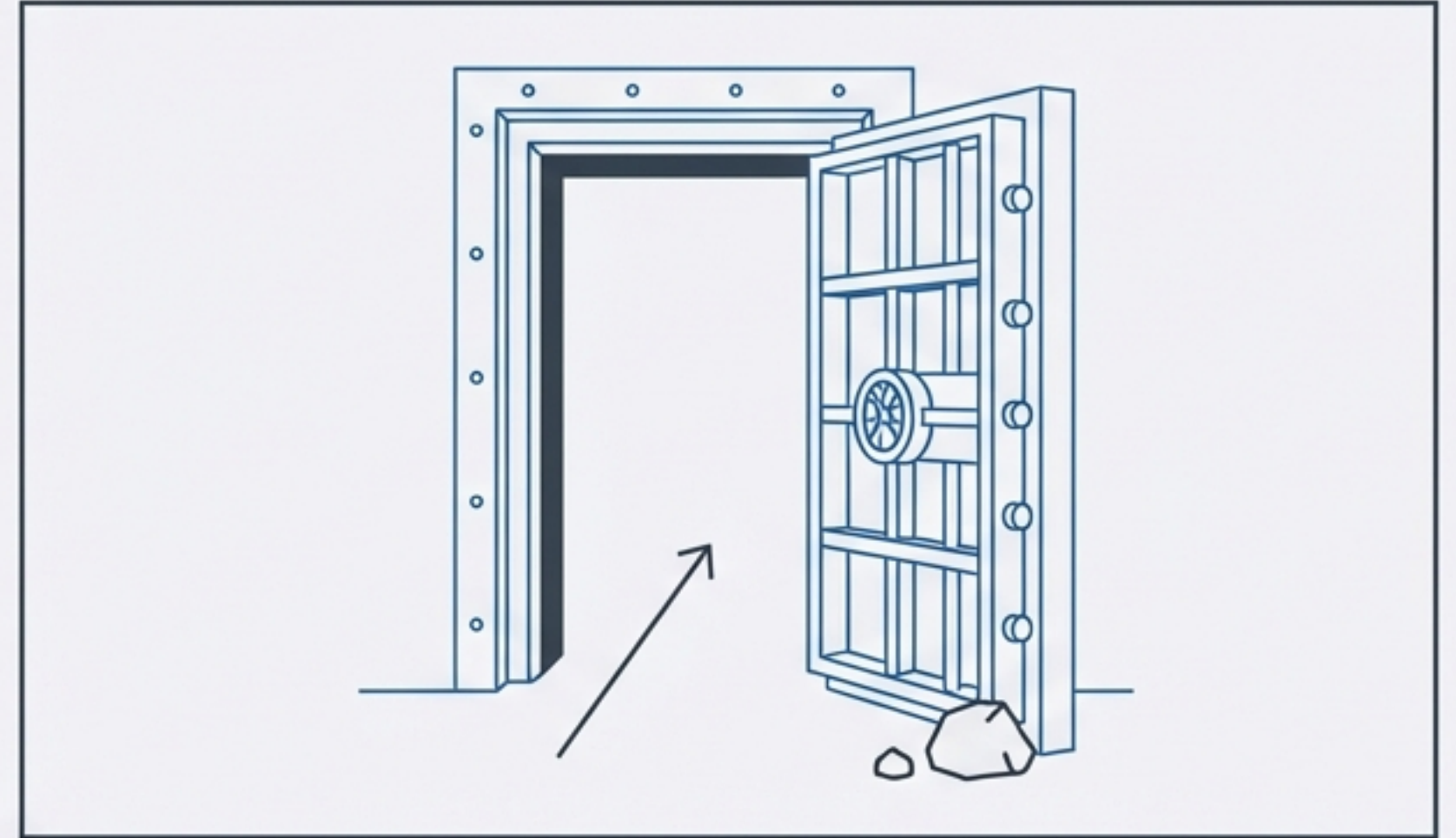
Calibrate to Reality, Not Movie Plots

MOVIE PLOT



THE TRAP: Preparing for zero-days and nation-state cryptography breakers.

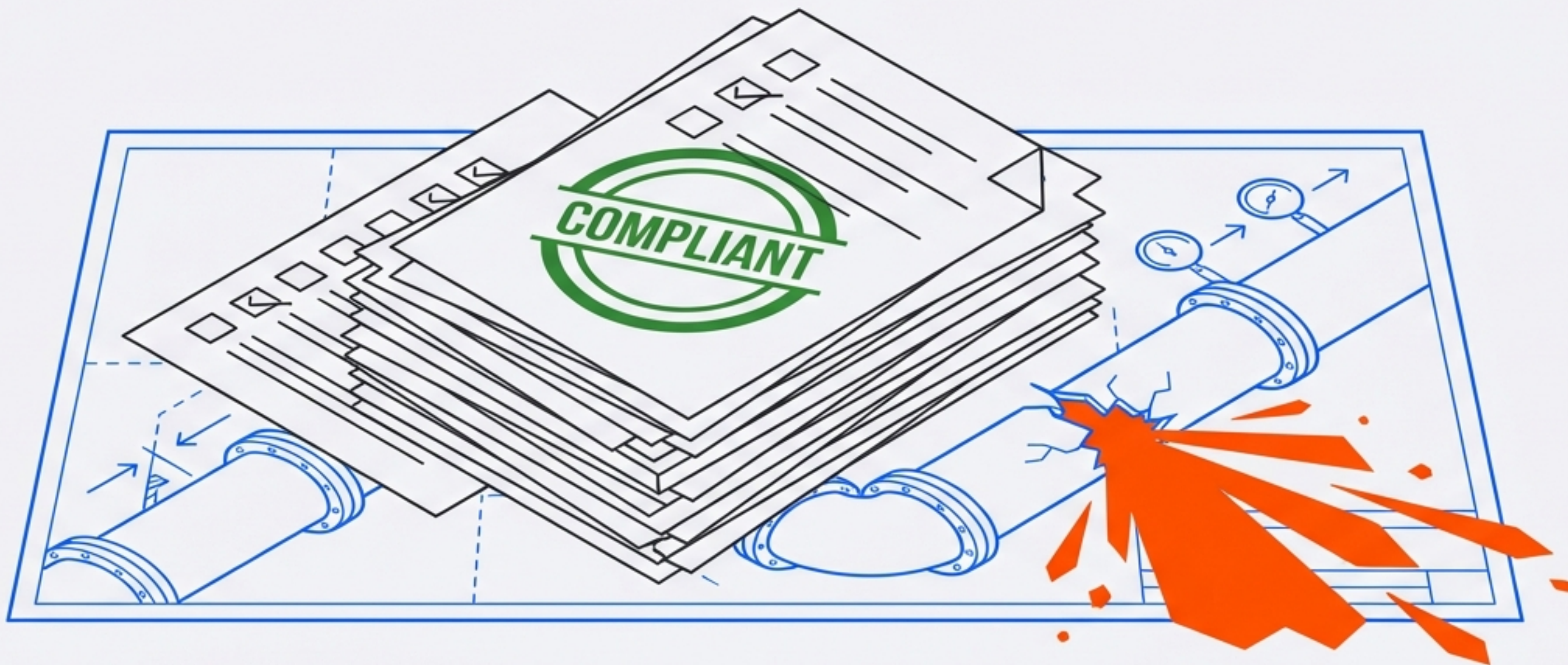
REALITY



THE REALITY: Unrotated keys, unencrypted laptops, and helpful agents.

“A house with a basic lock is safer than a bunker with an open door.”

The Compliance Tax



THE PROBLEM:

'Compliance Theatre' creates busy work that crowds out actual security improvement.

THE ANTIDOTE:

Actual incidents (P3s) act as a razor. They cut through the paperwork to reveal where the real holes are.

THE SHIFT:

Use the Near Miss to prioritize work that compliance ignores but reality demands.

Infrastructure is Security

THEATRE



Actionable
Intelligence:
None.

ACTUAL SECURITY



Code



Build



Test



Deploy



Time to fix:
4 Minutes.

If you cannot fix a bug in minutes via a robust pipeline, you have no security.

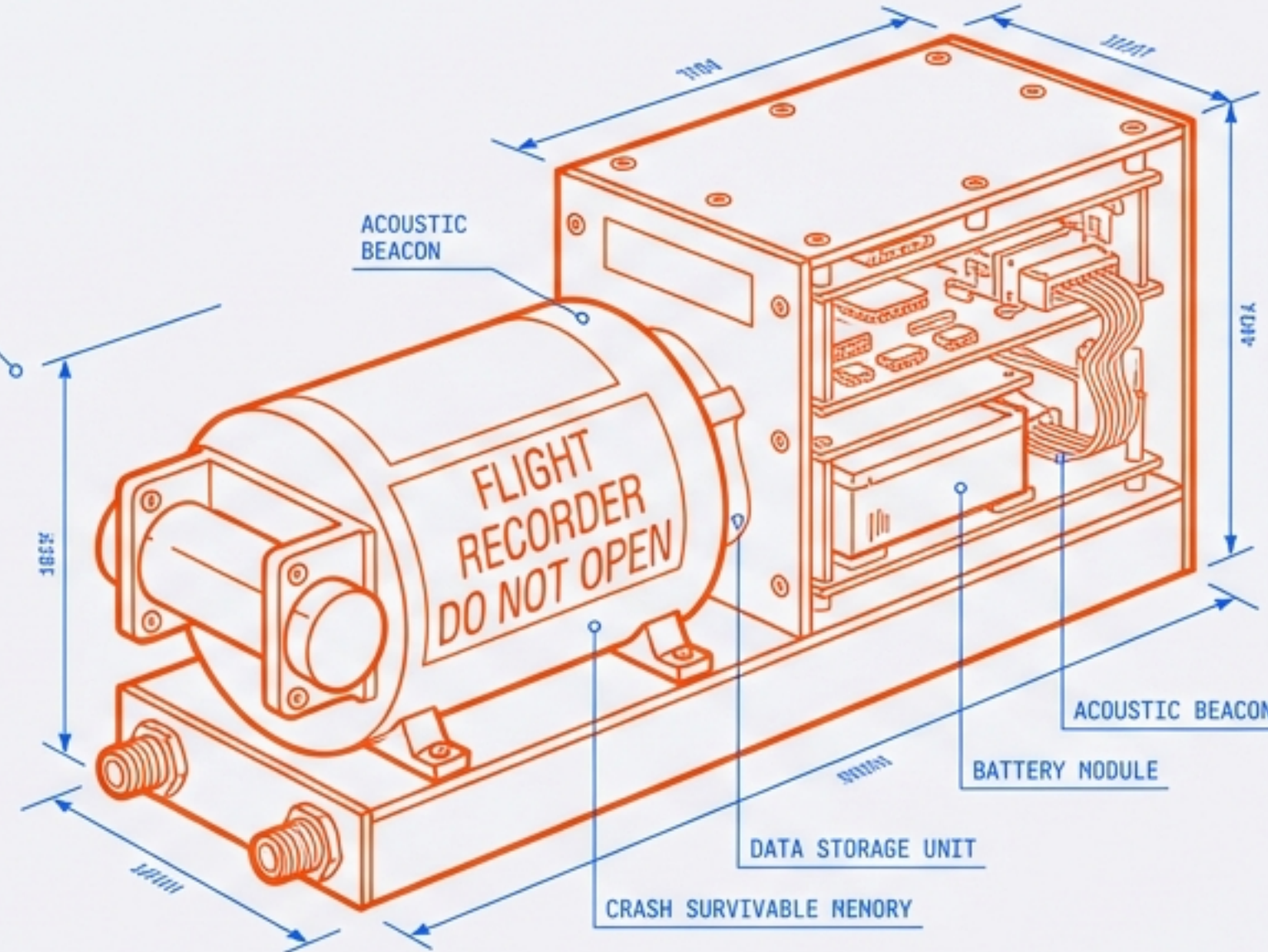
The right security investment is often a better deployment pipeline, not a new security vendor.

Learning from Aviation & Hyperscalers

THE AVIATION STANDARD

A “near miss” triggers the same investigation level as a crash.

The systemic causes are identical; only luck separates them.



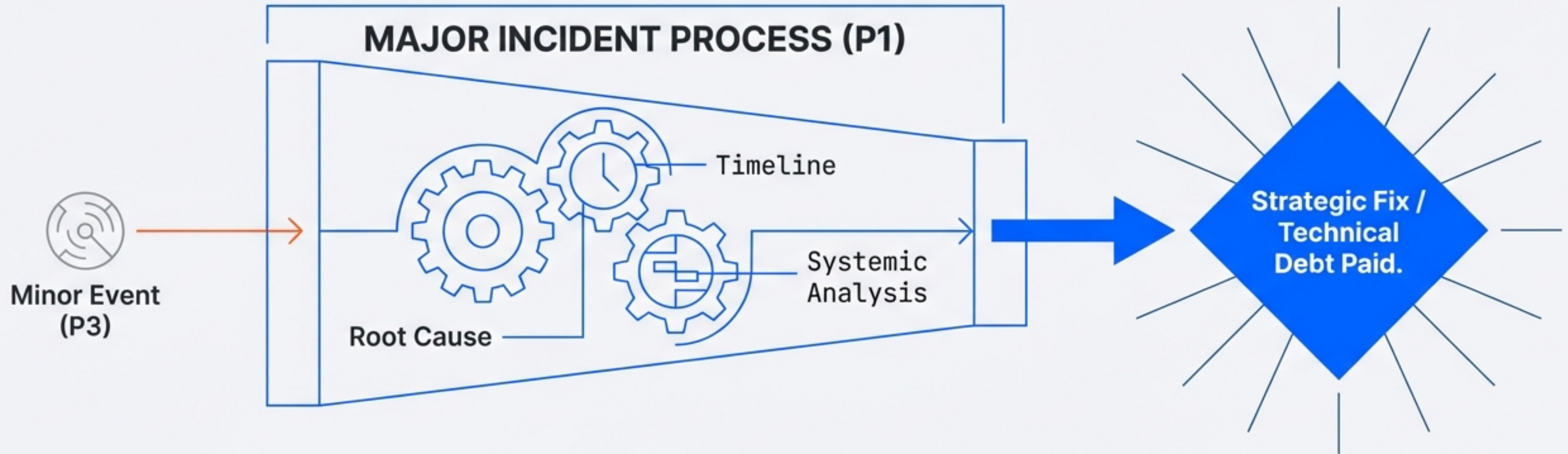
THE AWS MODEL

Correction of Errors (COE).

Analyzing operational events that didn't become P1s to find the threads that would have caused them.

You don't wait for the plane to crash to fix the engine.

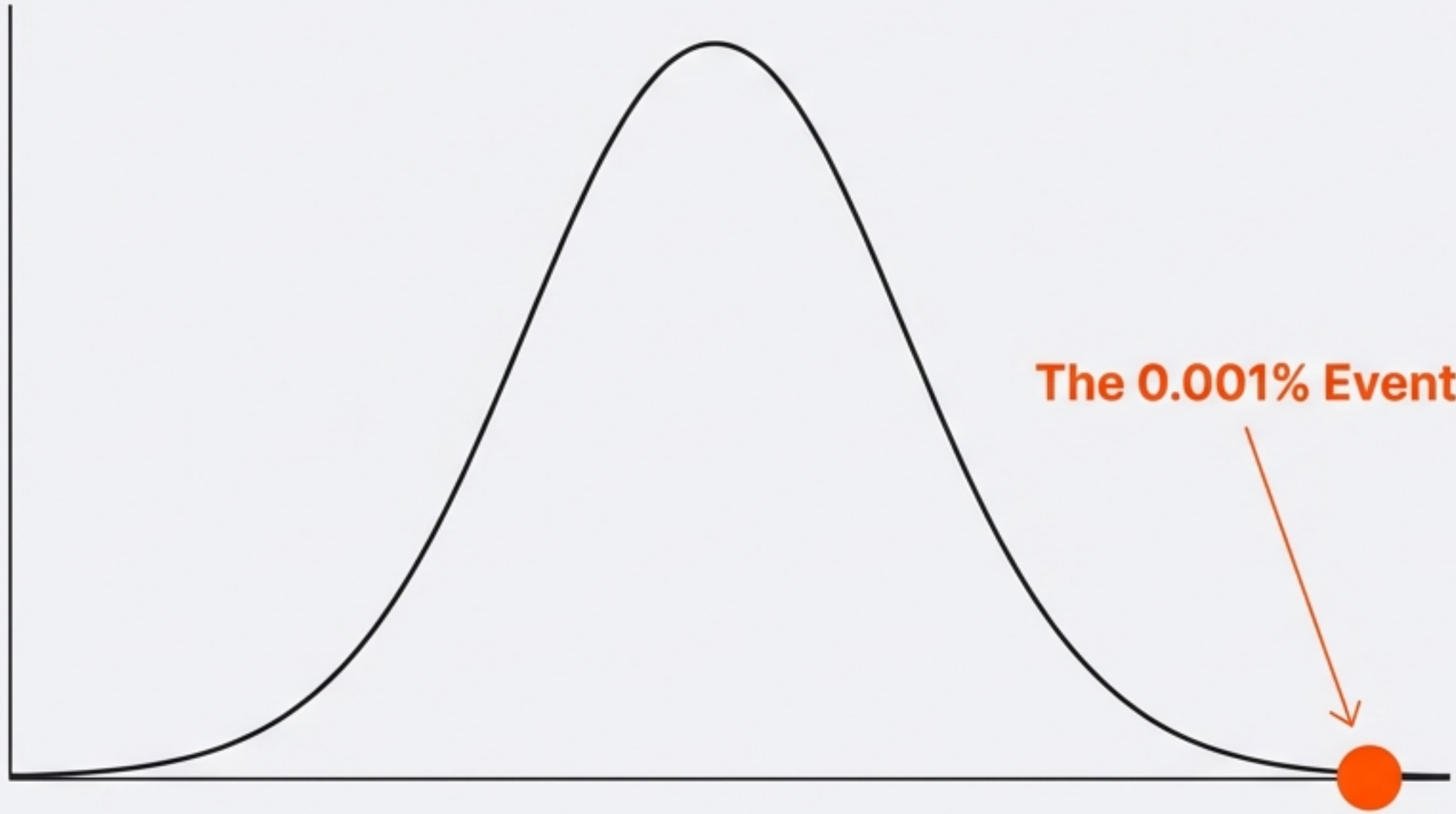
The Methodology: P3-as-P1



DEFINITION: Running minor incidents (P3) with Major Incident (P1) process levels.

STRATEGY: Use the 'Near Miss' to burn political capital. Manufacture urgency while the damage is zero.

The Probability Shift



THE REALIZATION:

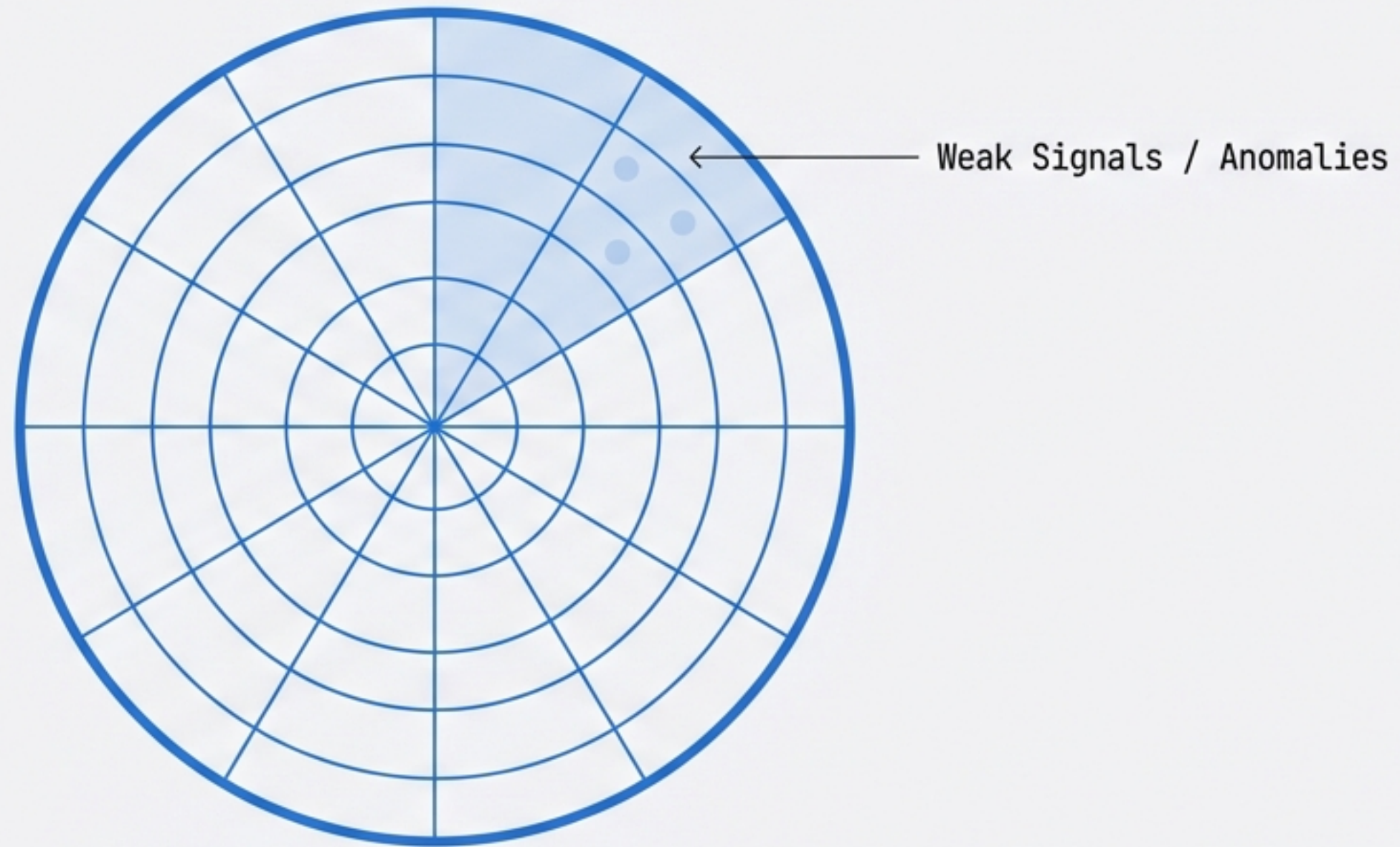
We dismiss outliers as "one-in-a-million".

But once the event happens, the probability is no longer 0.001%. It is 100%.

If the "impossible" happened, your probability model was wrong.

What ELSE is now within the realm of possibility?

A Culture of “Weak Signals”



THE VISION:

A team where every role notices the oddities.

THE LITMUS TEST:

When asked “How many times has this happened before?”, there must be an answer.

THE FAILURE STATE:

If the answer is “We don’t know”, that lack of visibility IS the incident.

Directives for the Agents



CISO & GRC

Accept risk based on the full envelope of possibility, not just the outcome.



QA

Ask "How was this possible?" for every bug. You are security at the code level.



SHERPA

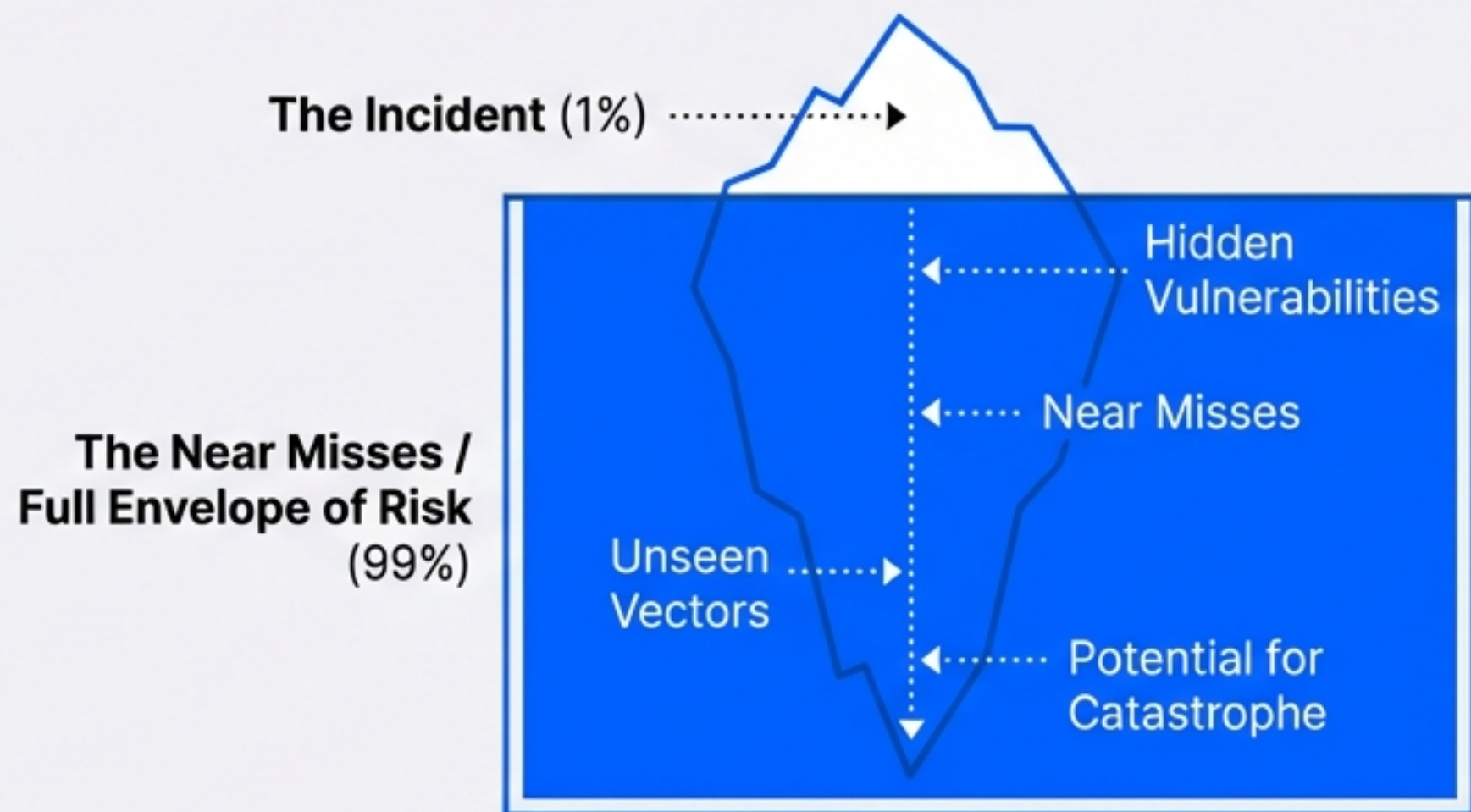
Watch for weak signals in user behavior. Anomaly detection is human.



DEVELOPERS

Ask "How could I make this change without a test failing?"

The Final Calculus



When you sign off on an incident report, you aren't just accepting what happened.
You are accepting everything that COULD have happened.

Be uncomfortable. Investigate the near miss. Do not build your safety on the hope that the next attacker will also turn right instead of left.

The risk you are accepting is the full envelope of what was possible.